

10.0 Avaliar os recursos de segurança do endpoint

A segurança de endpoint protege todos os endpoints conectados a uma rede, de notebooks a smartphones, tablets e outros dispositivos de IoT, para evitar que sejam um ponto de entrada de ataque. A segurança efetiva do endpoint vem ganhando importância à medida que o número e os tipos de dispositivos conectados às redes continuam aumentando.

No caso de dispositivos de computação tradicionais, como computadores de mesa e notebooks, as práticas de hardening (proteção) normalmente garantem que os sistemas operacionais e todos os aplicativos instalados sejam atualizados regularmente, o acesso do usuário seja limitado, os firewalls e o software antivírus estejam ativados e atualizados e os softwares, serviços e as portas não utilizados sejam desativados ou removidos para minimizar possíveis vetores de ataque.

As estratégias de segurança podem incluir considerações adicionais para dispositivos móveis como smartphones e tablets. Embora manter o sistema operacional e os aplicativos atualizados ainda seja crucial, outras práticas, como desativar recursos desnecessários (p. ex., Bluetooth e NFC fora de uso), limitar as permissões dos aplicativos e evitar redes Wi-Fi não seguras, tornam-se cada vez mais importantes. Instalar aplicativos de segurança confiáveis, ativar a criptografia do dispositivo e impor bloqueios de tela são considerações essenciais. As soluções de gerenciamento de dispositivos móveis (MDM) ajudam a gerenciar e controlar os recursos de segurança em múltiplos dispositivos móveis.

O hardening de sistemas integrados e dispositivos da IoT se concentra na segurança física e na integridade do firmware, pois esses sistemas geralmente controlam os processos físicos ou estão localizados em ambientes não seguros. Aplicar atualizações regulares de firmware, empregar processos de inicialização segura para manter a integridade do firmware e garantir que as comunicações sejam criptografadas são práticas comuns. Como esses sistemas têm recursos computacionais limitados, eles exigem soluções de segurança leves mas robustas.

Nesta lição, você vai fazer o seguinte:

- Explorar a importância do hardening do endpoint.
- Compreender as técnicas de hardening.
- Conhecer os desafios específicos do hardening de dispositivos integrados.
- Saber mais sobre como fazer o hardening dos dispositivos móveis.
- Explicar a importância do gerenciamento de dados móveis.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O hardening de dispositivos descreve a prática de alterar as configurações para proteger sistemas contra ameaças, reduzindo as vulnerabilidades atribuídas às configurações padrão. As técnicas padrão incluem processos de atualização regulares, políticas de senha segura, o princípio do privilégio mínimo e a desativação ou remoção de softwares, serviços e recursos desnecessários a fim de reduzir a superfície de ataque de um dispositivo. Além disso, a criptografia de dados e as estratégias de hardening no âmbito da rede, como a implementação de firewalls e sistemas de detecção de intrusão, podem ajudar os analistas de segurança a monitorar e manter configurações seguras. Auditorias regulares de segurança e avaliações de vulnerabilidades garantem a segurança contínua do sistema e respostas rápidas a ameaças emergentes.

Objetivos abordados no exame:

- 2.5 Explicar o propósito das técnicas de mitigação para proteger a empresa.
- 4.1 Considerando determinado cenário, aplicar técnicas de segurança comuns aos recursos de computação.
- 4.5 Explicar as implicações de segurança do gerenciamento adequado de hardware, software e ativos de dados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Segurança do sistema operacional

A segurança do sistema operacional abrange muitas práticas que visam proteger contra acessos não autorizados, violações de dados, infecções por malwares e outras ameaças à segurança. Há muitas considerações e requisitos ao proteger um sistema operacional, pois os sistemas operacionais são produtos de software complicados e potentes, que operam no núcleo de todos os sistemas de informação. Muitos conceitos de segurança se aplicam à segurança do sistema operacional, incluindo controles de acesso, mecanismos de autenticação, configurações seguras, segurança de aplicativos, codificação segura, gerenciamento de patches, proteção de endpoint, treinamento de conscientização de usuários e monitoramento.

Hardening (proteção) descreve a alteração de um sistema operacional ou aplicativo para que ele funcione com segurança. A necessidade de hardening deve levar em conta as necessidades funcionais e de usabilidade, pois o hardening muitas vezes pode afetar negativamente a forma como os aplicativos funcionam ou operam entre si.

Os parâmetros de práticas recomendadas desempenham um papel crítico no hardening de dispositivos: eles fornecem um conjunto padrão de diretrizes ou listas de conferência para configurar dispositivos com segurança. Esses parâmetros, geralmente desenvolvidos por especialistas ou organizações de segurança cibernética, são um ponto de partida para os administradores de sistemas garantirem que os dispositivos sejam configurados de acordo com os padrões de segurança do setor. Muitos dos requisitos podem ser aplicados automaticamente por meio de um modelo de parâmetros de configuração. O princípio central é a mínima funcionalidade: um sistema deve executar apenas os protocolos e serviços necessários para os usuários legítimos. Isso reduz a superfície de ataque em potencial.

- As interfaces fornecem uma conexão à rede, e algumas máquinas podem ter mais de uma interface. Por exemplo, pode haver interfaces com fio e wireless ou uma interface de modem. Algumas máquinas podem vir com uma placa de interface de rede de gerenciamento. Se alguma dessas interfaces não for necessária, ela deve ser explicitamente desativada, em vez de simplesmente deixada sem uso.
- Os serviços fornecem uma biblioteca de funções para diferentes tipos de aplicativos. Alguns serviços oferecem suporte a recursos locais do sistema operacional e aplicativos instalados. Outros dão suporte a conexões remotas de clientes para aplicativos de servidor. Os serviços não utilizados devem ser desativados.
- As portas de serviço de aplicativos permitem que o software cliente se conecte a aplicativos em uma rede. Elas devem ser desativadas ou bloqueadas em um firewall se o acesso remoto não for necessário. É importante lembrar que um servidor pode ser configurado com uma porta não padrão. Por exemplo, um servidor HTTP pode ser configurado para usar a porta 8080 em vez da 80. Por outro lado, um malware pode tentar enviar dados não padronizados por uma porta aberta. Um sistema de detecção de intrusão deve detectar dados da rede que não correspondem ao formato de protocolo esperado.
- O armazenamento persistente armazena os dados do usuário gerados por aplicativos, além de credenciais em cache. A criptografia de disco é essencial para a segurança dos dados. Unidades autcriptografadas podem ser usadas para que todos os dados em repouso sejam sempre armazenados com segurança.

Também é importante estabelecer um ciclo de manutenção para cada dispositivo e manter-se atualizado sobre novas ameaças de segurança e respostas para os produtos de software específicos que você está executando.

Estações de trabalho

As estações de trabalho operam na linha de frente das atividades de uma organização e exigem considerações particulares em relação ao hardening de endpoints em comparação com outros dispositivos. Devido às tarefas variadas e aos inúmeros aplicativos associados ao uso da estação de trabalho, elas geralmente têm uma grande superfície de ataque. As práticas de hardening para minimizar essa superfície de ataque incluem a remoção de softwares desnecessários, a limitação de privilégios administrativos, o gerenciamento rigoroso da instalação e de atualizações de aplicativos e muitas outras mudanças. Além disso, como os funcionários operam estações de trabalho, estratégias de segurança focadas no usuário são essenciais, incluindo treinamento regular e atividades de conscientização para educar os usuários sobre ameaças como phishing e promover comportamentos seguros, como a adoção de senhas fortes, uso responsável da Internet e manuseio cuidadoso de dados confidenciais, entre outras práticas.

É essencial configurar a estação de trabalho para maximizar a segurança, como atualizações automáticas ativas, bloqueios de tela, firewalls, proteção de endpoints, detecção e prevenção de intrusão, maior registro em log, criptografia, monitoramento e muitas outras proteções. Além disso, a necessidade de proteger dispositivos periféricos, como portas USB, é especialmente crítica para estações de trabalho devido à sua utilização diversificada e alta exposição. Muitas

vezes, isso é alcançado por meio do uso de recursos de software para a proteção de endpoints e da implementação de políticas rígidas de controle de dispositivos. Por fim, dadas as diversas funções e responsabilidades das estações de trabalho, a segmentação é crucial para restringir as comunicações e limitar o potencial de propagação de malware ou invasores pela rede.

Configurações de linha de base e definições de registro

É comum possuir [[baselines de configuração]] separadas para clientes desktop, servidores de arquivos e impressão, servidores de DNS, servidores de aplicação, servidores de serviços de diretório e outros tipos de sistemas. No Windows, as definições de configurações são armazenadas no registro. Em uma rede de domínio do Windows, cada computador associado ao domínio recebe configurações de política de um ou mais objetos de política de grupo (GPOs). Essas configurações de política são aplicadas ao registro sempre que um computador é inicializado. Quando os hosts são gerenciados centralmente e executam apenas aplicativos e serviços autorizados, não há grandes motivos para alterar os valores de registro relevantes para a segurança. Os direitos de modificar o registro devem ser concedidos apenas para contas de usuário e serviço com base no privilégio mínimo necessário. É possível configurar um sistema de detecção de intrusão baseado em host para alertar sobre eventos de registro suspeitos.

Um relatório de desvio da linha de base consiste em testar a configuração real dos hosts para garantir que ela atende ao modelo de linha de base. Em redes Windows, a ferramenta Microsoft Baseline Security Analyzer (MBSA) foi muito usada para validar a configuração de segurança. O MBSA e outras ferramentas de relatórios da Microsoft foram substituídos pelo Kit de Ferramentas de Conformidade de Segurança(docs.microsoft.com/pt-br/windows/security/threat-protection/security-compliance-toolkit-10 (<https://docs.microsoft.com/en-us/windows/security/threat-protection/security-compliance-toolkit-10>)).

Figura 1. Uso do Security Compliance Manager para comparar as configurações em um GPO de produção com as configurações modelo de política da Microsoft.



Captura de tela usada com permissão da Microsoft.

Descrição

A janela de comparação de baselines possui cinco botões expansíveis: resumo, configurações que diferem (16), configurações que coincidem (12), configurações somente na baseline A (985) e configurações somente na baseline B (0). Os três primeiros botões estão expandidos. O texto sob resumo diz: Baseline A: WS2016 Domain Controller Security Compliance 1.0. Baseline B: Default Domain Controllers Policy 0.0. Total de configurações exclusivas comparadas: 1.013. Total de configurações em comum: 28. Total de configurações não coincidentes: 985. Os botões expansíveis segundo e terceiro listam nome, baseline A, baseline B e caminho da interface do usuário em formato de tabela. Botões Exportar para Excel e Fechar (selecionado) estão no canto inferior direito.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

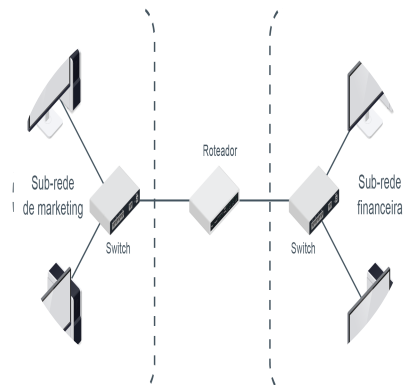
Resumo do que eu entendi: basicamente hardening seria o processo de endurecimento de hardware que temos disponíveis. Se você não usa ssh para gerenciar máquinas na sua rede de trabalho, desative ele de todas as máquinas. Todas as portas abertas são uma porta de invasão para pessoas má intencionadas acessarem a sua rede. Isso também se aplica a softwares e blotwares que vem no sistema. Baselines seguras são como "configurações padrões seguras" que você pode seguir caso queira. A Microsoft disponibiliza um tool kit para a conferencia em alguns sistemas operacionais e pacotes dela.

O objetivo do hardening de dispositivos é aprimorar a segurança de um sistema reduzindo as possíveis vulnerabilidades que uma entidade mal-intencionada pode explorar. Isso é possível por meio de configurações de rede e definições de sistema para reduzir a superfície de ataque.

Segmentação

A segmentação é crucial para proteger um ambiente corporativo, pois reduz o impacto potencial de um incidente de segurança cibernética, isolando os sistemas e limitando a disseminação de um ataque ou infecção por malware. Em uma rede segmentada, os sistemas são divididos em segmentos ou sub-redes separadas, cada um com controles de segurança e permissões de acesso distintos. Esse tipo de segmentação complica significativamente o trabalho de um invasor, dando a uma organização mais tempo para detectar e responder a um ataque. Além disso, a segmentação permite um controle mais detalhado sobre o acesso aos dados para garantir que usuários, dispositivos e aplicativos tenham acesso apenas às informações necessárias para suas tarefas específicas, o que aumenta a proteção e privacidade dos dados.

Figura 1. Uma rede segmentada que mostra as sub-redes de marketing e finanças e o posicionamento dos dispositivos da rede. O tráfego entre as duas redes é controlado pelo roteador.



Imagens © 123RF.com.

Isolamento

[Isolamento] de dispositivos refere-se à segregação de dispositivos individuais dentro de uma rede para limitar sua interação com outros dispositivos e sistemas. Isso visa aprimorar a proteção dos endpoints impedindo a disseminação lateral de ameaças, caso um dispositivo seja comprometido. No contexto da proteção de endpoints, o isolamento cria barreiras entre os dispositivos, de modo que uma ameaça que se infiltre em um deles não consiga se espalhar facilmente para outros. O isolamento de dispositivos restringe o tráfego de rede entre dispositivos, reduzindo a possível superfície de ataque. Essa abordagem é particularmente útil para ameaças como worms ou ransomware, que muitas vezes visam se propagar rapidamente pelas redes. O isolamento de dispositivos também limita os impactos da violação porque garante que os dispositivos comprometidos não possam acessar toda a rede.

Antivírus e antimalware

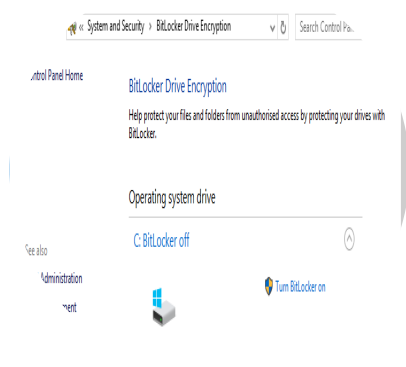
A primeira geração de softwares **[antivírus]** é caracterizada pela detecção e prevenção baseada em assinaturas de vírus conhecidos. Um antivírus (AV) agora executa a detecção generalizada de malware, não apenas vírus e worms, mas também cavalos de troia, spyware, PUPs, cryptojackers, entre outros. Embora os antivírus continuem sendo importantes, a detecção baseada em assinatura é amplamente reconhecida como insuficiente para a prevenção de violações de dados.

Criptografia de disco

A **[criptografia de disco completo (FDE)]** significa que todo o conteúdo da unidade (ou volume), incluindo arquivos e pastas do sistema, é criptografado. As medidas de segurança baseadas em ACL do sistema operacional são muito fáceis de contornar se um adversário conseguir conectar a unidade a um sistema operacional de host diferente. A criptografia da unidade resolve esse problema de segurança disponibilizando o conteúdo apenas em combinação com a chave de criptografia correta. A criptografia de disco pode ser aplicada a unidades de disco rígido (HDDs) e unidades de estado sólido (SSDs).

A FDE demanda o armazenamento seguro da chave usada para criptografar o conteúdo da unidade. Normalmente, ela é armazenada em um módulo de plataforma confiável (TPM). O chip TPM possui uma área de armazenamento segura na qual um programa de criptografia de disco, como o Windows BitLocker, pode gravar suas chaves. É possível também usar uma unidade USB removível (se o USB for uma opção de dispositivo de inicialização). Como parte do processo de configuração, você cria uma senha de recuperação ou chave. Ela poderá ser usada se o disco for movido para outro computador ou se o TPM for danificado.

Figura 2. Ativação da criptografia da unidade do BitLocker.



Captura de tela usada com permissão da Microsoft.

Descrição

O painel esquerdo exibe: página inicial do painel de controle, seguido de administração do TPM, gerenciamento de disco e declaração de privacidade sob o título ver também. O painel direito está dividido em duas seções. A seção superior é intitulada Criptografia de Unidade BitLocker. O texto abaixo diz: Ajude a proteger seus arquivos e pastas contra acesso não autorizado protegendo suas unidades com o BitLocker. A seção inferior é intitulada unidade do sistema operacional.

O link abaixo exibe: C: BitLocker desativado. Há um link ativar BitLocker à direita.

Uma das desvantagens da FDE é que, como o sistema operacional executa as operações criptográficas, o desempenho é reduzido. Esse problema é mitigado por meio do uso de [[unidades autocriptografadas (SED)]] , nas quais as operações criptográficas são realizadas pelo próprio controlador da unidade. A SED utiliza uma chave simétrica de criptografia de dados/mídia (DEK/MEK) para criptografia em grande volume e armazena a DEK de forma segura, criptografando-a com um par de chaves assimétricas chamado de chave de autenticação (AK) ou [[chave de criptografia de chave (KEK)]]. O uso da AK é autenticado pela senha do usuário. Logo, a senha do usuário pode ser alterada sem precisar descriptografar e criptografar novamente a unidade. Os primeiros tipos de SEDs utilizavam mecanismos proprietários, mas muitos fornecedores atualmente desenvolvem com base na Especificação [[Opal Storage]], criada pelo Trusted Computing Group (TCG).

Descrição

Laptops,
computadores,
dispositivos
móveis e
servidores

Descrição

A criptografia completa do disco garante que os dados confidenciais sejam protegidos mesmo se o dispositivo de armazenamento for removido ou acessado diretamente usando outros métodos. Nas máquinas virtuais, a FDE impede o acesso direto aos dados armazenados no arquivo de disco da máquina virtual.

Descrição	Descrição
Dispositivos de IoT	Os dispositivos da Internet das Coisas (IoT), como dispositivos domésticos inteligentes, wearables e sensores industriais, geralmente coletam e transmitem dados confidenciais. A criptografia completa do disco impede o acesso não autorizado a esses dados se os dispositivos forem comprometidos.
Unidades de disco rígido externas e unidades flash USB e mídias externas	Os dispositivos de armazenamento portáteis são propensos a perda ou roubo. A criptografia completa do disco garante que os dados armazenados nesses dispositivos permaneçam protegidos, dificultando significativamente o acesso ou a recuperação das informações por indivíduos não autorizados.

Gerenciamento de patches

Nenhum sistema operacional, aplicativo de software ou implementação de firmware está livre de vulnerabilidades. Logo que uma vulnerabilidade é identificada, os fornecedores tentam corrigi-la. Ao mesmo tempo, os invasores tentam explorá-la. Scanners automatizados de vulnerabilidades podem identificar de forma eficaz patches ausentes no sistema operacional, além de uma ampla variedade de aplicativos de terceiros e dispositivos/firmware. Essa varredura só é útil se houver procedimentos eficazes para aplicar os [[patches]] ausentes.

Em redes residenciais e pequenas, os hosts geralmente são configurados para fazerem a atualização automática, sendo assim eles verificam e instalam patches automaticamente. Os principais sistemas operacionais e produtos de software de aplicativos tem um suporte bom em termos de correções oferecidas pelo fornecedor para problemas de segurança. No Windows, esse processo é feito por meio do Windows Update, enquanto no Linux ele pode ser configurado via `yum-cron` ou `apt unattended-upgrades`, dependendo do gerenciador de pacotes usado pela distribuição.

No entanto, as redes corporativas precisam ser cautelosas em relação à implantação automatizada, pois um patch incompatível com um aplicativo ou fluxo de trabalho pode causar problemas de disponibilidade. Em casos raros, como o notório hack SolarWinds ([npr.org/2021/04/16/985439655/a-worst-nightmare-cyberattack-the-untold-story-of-the-solarwinds-hack?t=1631031433646](https://www.npr.org/2021/04/16/985439655/a-worst-nightmare-cyberattack-the-untold-story-of-the-solarwinds-hack?t=1631031433646) (<https://www.npr.org/2021/04/16/985439655/a-worst-nightmare-cyberattack-the-untold-story-of-the-solarwinds-hack?t=1631031433646>)), os repositórios de atualizações podem ser infectados por malware que pode ser espalhado por meio de atualizações automatizadas.

Também pode haver problemas de desempenho e gerenciamento quando vários aplicativos executam clientes de atualização no mesmo host. Por exemplo, além do atualizador do sistema operacional, provavelmente haja uma atualização de software de segurança, atualizador de navegador, atualizador Java, atualizador de driver OEM e assim por diante. Esses problemas podem ser mitigados com a implantação de uma suíte corporativa de [gerenciamento de patches]. Algumas suítes, como o System Center Configuration Manager (SCCM)/Endpoint Manager da Microsoft (docs.microsoft.com/en-us/mem/configmgr (<https://docs.microsoft.com/en-us/mem/configmgr>))), são específicas do fabricante, enquanto outras são projetadas para oferecer suporte a aplicativos de terceiros e a múltiplos sistemas operacionais.

Testar patches antes de implantá-los no ambiente de produção é crucial para manter a estabilidade e a segurança do software. Ao realizar testes completos, as organizações podem identificar possíveis problemas ou conflitos decorrentes do patch, garantindo que ele não introduza novas vulnerabilidades ou interrompa operações críticas. Os testes ajudam a

mitigar o risco de consequências não intencionais e facilitam um processo de implantação mais controlado, protegendo a integridade e a confiabilidade do ambiente. Esse procedimento é normalmente realizado em ambientes de teste construídos para simular o ambiente de produção o tanto quanto possível.

Além disso, pode ser difícil agendar operações de patch, especialmente se a aplicação do patch criar um risco de disponibilidade para um sistema crítico. Se as avaliações de vulnerabilidade destacarem continuamente problemas de patches em falta, os procedimentos de gerenciamento de patches devem ser atualizados. Se o problema afetar apenas alguns hosts, isso pode indicar um comprometimento que deve ser investigado mais de perto.

O gerenciamento de patches pode ser difícil para sistemas legados, sistemas proprietários e sistemas de fornecedores sem planos robustos de gerenciamento de segurança, como alguns tipos de dispositivos da Internet das Coisas. Esses sistemas precisarão de controles de compensação ou alguma outra forma de mitigação de risco se os patches não estiverem prontamente disponíveis.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo de entendimento: proteção de endpoint seria todo o processo que é utilizado para a prevenção de invasões e vazamento de informações sensíveis dentro de um dispositivos. No texto são explicadas várias formas de se fazer essa proteção, desde a camada da rede até a camada de gerenciamento dos dispositivos no local e também, em software.

Criptografia de disco são um dos tópicos bem importantes também que o texto cita aqui, onde a sigla FDE seria a criptografia completa do disco, a unidade autogriptografada que seria a SDE que vem como uma solução para a FDE porque criptografa arquivos em tempo real (tudo literalmente, arquivos da pasta home, temporários, configurações).

Comunicação de chaves simétricas e chaves privadas são mencionadas nesse tópico também, onde uma autenticação precisa ser feita para acessar seus dados, que tem o nome de chave de criptografia de acesso KEK, nesse caso, entendi como se fosse no meu Linux, ele pede a autenticação em forma de senha para que eu possa acessar minha máquina. Patches de atualizações são uma forma importante de corrigir vulnerabilidades em softwares e sistemas operacionais. Sempre temos um embate nessa parte, onde um recomenda que seja sempre atualizado e outro, pra prosseguir com cautela em grades empresas, pois sistemas podem quebrar a comunicação caso o patch venha com problemas ou uma versão diferente apenas não surta o efeito esperado com a comunicação interna.

Detecção e resposta de endpoint (EDR) e detecção e resposta estendidas (XDR)

Um [[produto de detecção e resposta em endpoint (EDR)]] tem como objetivo fornecer visibilidade em tempo real e histórica sobre o comprometimento, conter o malware em um único host e facilitar a remediação do host para seu estado original. O termo “EDR” foi cunhado pelo pesquisador de segurança do Gartner Anton Chuvakin, e o Gartner produz relatórios anuais de “Quadrante Mágico” para as funcionalidades EPP ([gartner.com/en/documents/3848470](https://www.gartner.com/en/documents/3848470)) (<https://www.gartner.com/en/documents/3848470>) e EDR em pacotes de segurança (<https://www.gartner.com/en/documents/3894086>) (<https://www.gartner.com/en/documents/3894086>)).

Apesar de pacotes de proteção de endpoint anteriores se reportarem a um servidor de gerenciamento local, é mais provável que os agentes de endpoint de última geração sejam gerenciados a partir de um portal de nuvem e usem inteligência artificial (IA) e aprendizado de máquina para realizar a análise de comportamento de usuários e entidades. Esses recursos de análise fariam parte da oferta do provedor de serviços de segurança.

Nota:

Observe que a detecção e resposta gerenciadas (MDR) é uma classe de serviço de segurança hospedado (digitalguardian.com/blog/what-managed-detection-and-response-definition-benefits-how-choose-vendor-and-more) (<https://digitalguardian.com/blog/what-managed-detection-and-response-definition-benefits-how-choose-vendor-and-more>)).

O EDR se concentra na proteção de dispositivos endpoint, como computadores, notebooks e dispositivos móveis, coletando e analisando dados dos endpoints para detectar, investigar e responder a ameaças avançadas que podem contornar as medidas de segurança tradicionais. As ferramentas de EDR fornecem monitoramento e coleta de dados de endpoints em tempo real, permitindo esforços rápidos de resposta e investigação. O software EDR é uma ferramenta importante que detecta e responde a ameaças persistentes avançadas e ransomware, bem como concede informações forenses valiosas após uma violação. A detecção e resposta estendidas (XDR) amplia o EDR, fornecendo recursos mais amplos de visibilidade e resposta, pois estende a proteção para além dos endpoints, incorporando dados da rede, plataformas de nuvem, gateway de e-mail, firewall e outros componentes essenciais de infraestrutura. Usando um escopo mais amplo, o XDR fornece uma visão abrangente dos recursos de tecnologia da informação para identificar ameaças de forma mais eficaz e permitir respostas mais rápidas.

Detecção/prevenção de intrusão baseada em host (HIDS/HIPS)

Os [[sistemas de detecção de intrusões baseados em host (HIDS)]] e os sistemas de prevenção de [[intrusões baseados em host (HIPS)]] descrevem ferramentas de software que monitoram e protegem hosts individuais, como computadores ou servidores, contra acessos não autorizados e atividades maliciosas. Ambas exigem a implantação e configuração de agentes de software especializados que monitoram e analisam continuamente os endpoints.

Os sistemas de HIDS e HIPS usam detecção baseada em assinatura, detecção de anomalias e análise de comportamento para identificar atividades suspeitas. Ambos os sistemas coletam e correlacionam dados de várias fontes, como logs do sistema, tráfego de rede e atividades do usuário, para identificar padrões e indicadores de comprometimento ou comportamento malicioso. Os sistemas de detecção de intrusão baseados em host se concentram

na detecção e alerta, fornecendo notificações aos administradores de sistemas ou à equipe de segurança quando atividades suspeitas são detectadas. Os sistemas de prevenção de intrusão baseados em host, por sua vez, detectam e respondem ativamente às ameaças bloqueando ou mitigando-as automaticamente.

Uma das principais funcionalidades do HIDS é o [[monitoramento de integridade de arquivos (FIM)]]. Isso pode ser implementado como um recurso independente. Quando um software é instalado a partir de uma fonte legítima (usando código assinado no caso do Windows ou um repositório seguro no caso do Linux), o gerenciador de pacotes do sistema operacional verifica a assinatura ou impressão digital de cada arquivo executável e notifica o usuário se houver um problema. O software de FIM audita os principais arquivos do sistema para garantir que eles correspondam às versões autorizadas. No Windows, o serviço de Proteção de Arquivos é executado automaticamente e a ferramenta System File Checker (SFC) pode ser usada manualmente para verificar os arquivos do sistema operacional.

Tripwire ([tripwire.com \(https://www.tripwire.com/\)](https://www.tripwire.com/)) e OSSEC ([ossec.net \(https://www.ossec.net/\)](https://www.ossec.net/)) são exemplos de ferramentas multiplataforma com opções para proteger uma gama mais ampla de aplicações. O monitoramento de integridade de arquivos é utilizado para detectar alterações em endpoints, como mudanças em arquivos importantes ou na configuração do sistema operacional. Quando detectadas, as alterações podem ser investigadas para determinar se são autorizadas.

Análise de comportamento do usuário (UBA)/Análise de comportamento do usuário e da entidade (UEBA)

A análise de comportamento do usuário (UBA), também conhecida como [[análise de comportamento de usuários e entidades (UEBA)]], é uma abordagem de cibersegurança baseada no monitoramento e na análise do comportamento dos usuários dentro de uma organização, visando detectar anomalias que possam indicar ameaças potenciais, como ameaças internas, contas comprometidas ou fraudes. A UBA utiliza aprendizado de máquina, ciência de dados e técnicas de análise estatística para estabelecer um perfil de linha de base para os usuários e entidades de uma organização, incluindo como, quando e onde eles acessam a rede, quais recursos usam e outros padrões de comportamento. Depois que os perfis de linha de base são estabelecidos, o sistema de UBA monitora e compara continuamente novos comportamentos em relação à linha de base estabelecida, alertando o pessoal de segurança sobre atividades incomuns ou suspeitas.

Por exemplo, a UBA alertaria sobre um usuário que baixa com frequência pequenos conjuntos de arquivos durante o horário comercial padrão, mas de repente começa a baixar grandes volumes de dados tarde da noite. Outro exemplo seria um usuário que normalmente faz login de um local específico dentro do país, mas de repente começa a fazer login no exterior. Essas atividades podem indicar uma possível violação de dados ou comprometimento de conta e acionar um alerta do sistema de UBA.

Estes são alguns dos produtos comerciais de UEBA disponíveis no momento em que este texto foi escrito:

- Splunk User Behavior Analytics

- QRadar User Behavior Analytics da IBM (<https://www.ibm.com/products/qradar-siem/user-behavior-analytics>) (<https://www.ibm.com/products/qradar-siem/user-behavior-analytics>))
- InsightIDR da Rapid7 (<https://docs.rapid7.com/insightidr/>) (<https://docs.rapid7.com/insightidr/>))
- Insider Threat da Forcepoint (<https://www.forcepoint.com/security/insider-threat>) (<https://www.forcepoint.com/security/insider-threat>))



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo entendimento: a proteção avançada de endpoints tende a coletar grandes volumes de logs para uma análise detalhada e profundo sobre o que é realmente a proteção. Temos como exemplo o ERD que seria para endpoints gerais como computadores, celulares e servidores. Já o XDR tem uma gama mais ampla e mais detalhada do que acontece dentro de uma rede completa. Para facilitar, pense no **EDR** como um segurança de shopping que olha apenas para o que acontece dentro de uma loja específica (o endpoint). O **XDR** é o centro de comando que olha as câmeras do estacionamento, o sensor de fumaça, o crachá na entrada e as transações no caixa, tudo ao mesmo tempo. HIDS e HIPS seriam software de monitoramento que verificam as integridades dos arquivos baixados nas máquinas e dos que já estão nelas também. Uma das funcionalidades mais populares deles são chamadas de FIM que é justamente o monitoramento de integridade do arquivo. Ele verifica a impressão digital de cada arquivo e notifica o usuário caso algo suspeito seja notado, sejam de arquivos Windows ou de repositórios confiáveis do Linux. Também é citado o UEBA e UBA, que são quase a mesma coisa praticamente, os que diferencia são que o UBA foca totalmente em comportamento humano e o UEBA é uma evolução do UBA, focando também em comportamento de endpoints (o que o sistema está baixando, o login que foi feito em qual horário). Eles tem foco na parte comportamental dos usuários para definir se tem algo de errado ou não dentro do sistema. Por exemplo, uma pessoal trabalha remoto de uma certa localização no país e do nada, hoje ela está na ponta da Rússia, suspeito não? Um usuário tende a baixar certa quantidade de arquivos dentre 13:00 e 17:00 da tarde e do nada, agora ele está baixando quantidades de arquivos gigantes na parte da madrugada, entre 02:00 a 04:00, suspeito não? O UEBA faz exatamente esses apontamentos para os gestores com IA e machine learning na parte de comportamento.

Se a segurança do endpoint for comprometida, é preciso considerar várias classes de vetores para a mitigação:

- **Engenharia Social:** se o malware foi executado por um usuário, utilize ações de educação e conscientização em segurança para reduzir o risco de ataques futuros. Revise as permissões para verificar se a conta poderia ser operada com um nível de privilégio inferior.
- **Vulnerabilidades:** se o malware explorou uma falha de software, instale o patch ou isole o sistema até que uma correção seja desenvolvida.

- **Ausência de Controles de Segurança:** se o ataque poderia ter sido prevenido por proteção de endpoint/antivírus, firewall de host, filtro de conteúdo, DLP ou MDM, avalie a possibilidade de implantar esses recursos no endpoint. Se isso não for viável, isole o sistema para evitar exploração pelo mesmo vetor.
- **Desvio de Configuração:** se o malware explorou uma alteração de configuração não documentada (como software shadow IT ou um serviço/porta não autorizado, por exemplo), reestabeleça a configuração baseline e revise os procedimentos de gerenciamento de configuração para evitar esse tipo de alteração ad hoc.
- **Configuração Fraca:** se a configuração foi aplicada corretamente, mas ainda assim foi explorada, revise o template para desenvolver configurações mais seguras. Certifique-se de que o template seja aplicado a hosts semelhantes.

Controle de acesso

O controle de acesso refere-se à regulamentação e ao gerenciamento das permissões concedidas a indivíduos, softwares, sistemas e redes para acesso a recursos ou informações. Os controles de acesso garantem que apenas entidades autorizadas possam realizar determinadas ações ou acessar certos dados, enquanto entidades não autorizadas têm o acesso negado. Os conceitos de controle de acesso se aplicam a redes, acesso físico, dados, aplicativos e nuvem.

Princípio do privilégio mínimo

A implementação do princípio do privilégio mínimo (PoLP) é fundamental para melhorar a proteção de endpoints e minimizar o risco de problemas de segurança. O princípio do menor privilégio estabelece que usuários, aplicativos e processos devem receber apenas as permissões mínimas necessárias para realizar suas funções, e nada além disso.

Existem vários métodos práticos para implementar o privilégio mínimo. Um primeiro passo essencial para implementar efetivamente o privilégio mínimo é auditar minuciosamente as funções, privilégios e responsabilidades do usuário. Esse processo permite que as organizações entendam qual acesso cada usuário precisa para desempenhar sua função de forma eficaz. Os controles e permissões de acesso podem ser ajustados para adotar um princípio de privilégio mínimo que reflita melhor os resultados da auditoria.

As ferramentas de gerenciamento de usuários e contas também são essenciais ao implementar o princípio do privilégio mínimo. A revisão e a remoção regulares de contas não utilizadas ou desnecessárias reduzem os alvos em potencial para um invasor. Da mesma forma, os privilégios temporários, que concedem direitos de acesso adicionais por um tempo limitado e apenas quando necessário, podem ajudar a manter os privilégios o mais restritivos possível.

Outra abordagem prática para restringir o acesso é usar o controle de acesso baseado em função (RBAC). O RBAC atribui direitos de acesso ao sistema com base em funções predefinidas, e cada função tem um conjunto cuidadosamente definido de permissões que correspondem aos requisitos de qualquer função específica da organização. Essa abordagem garante que os usuários tenham acesso suficiente para executar suas tarefas, mas nada mais.

O princípio do privilégio mínimo também se aplica a aplicativos de software e sistemas operacionais, não apenas aos usuários. Por exemplo, garantir que os aplicativos sejam executados com as permissões mínimas necessárias pode impedir que sejam explorados para executar ações privilegiadas.

Listas de controle de acesso

As listas de controle de acesso (Access Control Lists, ACL) em sistemas e redes de computadores são usadas para impor políticas de controle de acesso. Uma ACL é uma lista de regras ou entradas que especificam quais usuários ou grupos têm acesso permitido ou negado a recursos específicos ou executam determinadas ações. Em redes, as ACL estão associadas a roteadores, firewalls ou dispositivos semelhantes e definem regras que determinam como o tráfego de rede é filtrado ou encaminhado com base em critérios como endereços de IP de origem, endereços de IP de destino, portas ou protocolos.

As ACL podem ajudar a controlar o acesso à rede e proteger contra atividades não autorizadas ou mal-intencionadas.

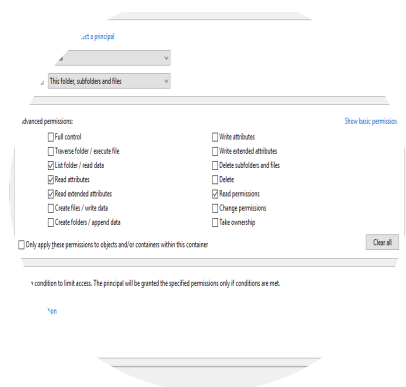
As ACL controlam o acesso a arquivos, diretórios ou recursos do sistema em sistemas operacionais e sistemas de arquivos. Cada entrada de controle de acesso (Access Control Entry, ACE) normalmente contém um identificador de usuário ou grupo e permissões associados que controlam as ações permitidas ou negadas. Essas permissões geralmente incluem ler, gravar, executar e, às vezes, limites mais granulares, como modificar, excluir ou listar.

Embora as ACL ofereçam flexibilidade e controle, o gerenciamento de políticas complexas de controle de acesso com várias entradas de ACL pode se tornar desafiador. A complexidade aumenta o risco de configurações incorretas. Portanto, o planejamento adequado, as revisões periódicas e as configurações que seguem práticas recomendadas são essenciais ao implementar e manter as ACL.

Permissões do sistema de arquivos

Com a segurança do sistema de arquivos, cada objeto nele tem uma lista de controle de acesso (Access Control List, ACL) associada. A ACL contém uma lista de contas (entidades) com permissão para acessar o recurso e as permissões que elas têm sobre ele. A ordem das ACE na ACL é importante para determinar as permissões efetivas de uma determinada conta. As ACL podem ser impostas por um sistema de arquivos compatível com permissões, como NTFS, ext3/ext4 ou ZFS.

Figura 1. Configuração de uma entrada de controle de acesso para uma pasta



(Captura de tela usada com permissão da Microsoft.)

Descrição

A tela está dividida em três seções. A primeira seção exibe: Principal: everyone, Tipo: Permitir, e Aplica-se a: Esta pasta, subpastas e arquivos. Um link selecionar um principal está presente no topo. A segunda seção, permissões avançadas, apresenta três caixas de seleção marcadas: ler atributos, ler atributos estendidos e ler permissões. Um link mostrar permissões básicas está no topo, e um botão limpar tudo na parte inferior. A terceira seção exibe: adicionar uma condição para limitar o acesso. O principal receberá as permissões especificadas apenas se as condições forem atendidas. Um link adicionar uma condição está localizado na parte inferior. Dois botões — OK (selecionado) e Cancelar — ficam no canto inferior direito.

Por exemplo, no Linux, existem três permissões básicas:

- **Read (r, leitura):** é a capacidade de acessar e visualizar o conteúdo de um arquivo ou listar o conteúdo de um diretório.
- **Write (w, gravação):** é a capacidade de salvar alterações em um arquivo ou criar, renomear e excluir arquivos em um diretório (também requer execução).
- **Execute (x, execução):** é a capacidade de executar um script, programa ou outro arquivo de software, ou a capacidade de acessar um diretório, executar um arquivo a partir desse diretório ou executar uma tarefa nesse diretório, como pesquisa de arquivos.

Essas permissões podem ser aplicadas no contexto do usuário proprietário (u), de uma conta de grupo (g) e de todos os outros usuários/mundo (). Uma cadeia de permissões lista as permissões concedidas em cada um desses contextos:

```
d rwx r-x r-x home
```

A cadeia de caracteres acima mostra que, para o diretório (d), o proprietário tem permissões de leitura, gravação e execução, enquanto o contexto do grupo e outros usuários têm permissões de leitura e execução.

O [[comando chmod]] é utilizado para modificar as permissões de arquivos em sistemas Unix/Linux. Ele pode ser usado no modo simbólico ou no modo absoluto. No modo simbólico, o comando funciona da seguinte maneira:

```
chmod g+w, o-x home
```

O efeito desse comando é acrescentar a permissão de gravação ao contexto do grupo e remover a permissão de execução do outro contexto. Por outro lado, o comando também pode ser usado para substituir as permissões existentes. Por exemplo, o comando a seguir aplica a configuração mostrada na primeira cadeia de permissões, que define as permissões como rwxr-xr-x:

```
chmod u=rwx,g=rx,o=rx home.
```

No modo absoluto, as permissões são atribuídas usando a notação octal, onde r=4, w=2 e x=1. Por exemplo, o comando a seguir tem o mesmo efeito:

```
chmod 755 home
```

Neste exemplo, o 755 corresponde às permissões atribuídas ao usuário, ao grupo e aos demais, onde as permissões do usuário são representadas por 7, as permissões do grupo por 5 e as permissões dos outros também por 5. Os números são gerados somando-se os valores associados a r (leitura), w (escrita) e x (execução). A única combinação de valores

que resulta em 7 é $4+2+1$, ou seja, r, w, x. Da mesma forma, a única combinação de valores que resulta em 5 é $4+1$, ou seja, r e x. Isso significa que o proprietário possui r, w e x, enquanto o grupo e os outros têm apenas r e x.

Listas de permissão e de bloqueio de aplicativos

Um elemento da configuração do endpoint é a política de controle de execução que define aplicativos que podem ou não ser executados.

- Uma `allow list` (ou lista de aprovação) nega a execução, a menos que o processo seja explicitamente autorizado.
- Uma `block list` (ou lista de bloqueio) geralmente permite a execução, mas proíbe explicitamente os processos listados.

O conteúdo das listas de permissão e das listas de bloqueio precisa ser atualizado em resposta a incidentes e à busca e ao monitoramento contínuos de ameaças.

A `threat hunting` também pode provocar uma mudança estratégica. Por exemplo, se você emprega principalmente negações explícitas mas seus sistemas estão sujeitos a inúmeras intrusões, terá de considerar a adoção de um modelo de “privilégios mínimos” e usar uma abordagem de negação a menos que esteja listado. No entanto, esse tipo de mudança pode ser altamente disruptiva, por isso deve ser precedida por uma avaliação de risco e uma análise de impacto nos negócios.

O controle de execução também pode ser difícil de configurar de forma eficaz, com muitas oportunidades para os agentes de ameaças escaparem dos controles. A análise detalhada do ataque pode sugerir a necessidade de mudanças no mecanismo existente ou de um sistema mais robusto.

Monitoramento

O monitoramento desempenha um papel vital no fortalecimento e hardening do endpoint, ajudando a aplicar e manter as medidas de segurança implementadas durante o processo de hardening. Quando os dispositivos já estão protegidos, o monitoramento ajuda a garantir que essas condições permaneçam vigentes.

Os analistas de segurança podem detectar mudanças que enfraquecem a configuração protegida por meio do monitoramento contínuo. Por exemplo, se uma porta anteriormente desabilitada for detectada como aberta ou um serviço desabilitado for habilitado, as ferramentas de monitoramento podem alertar os analistas sobre a mudança, que pode indicar uma violação.

Além disso, o monitoramento pode fornecer dados valiosos para fins de conformidade e auditoria. Relatórios regulares sobre o status dos dispositivos de endpoint podem verificar se os parâmetros de referência para hardening foram efetivamente implantados e mantidos, apoiando a conformidade com vários regulamentos e padrões do setor.

Imposição de configuração

A imposição de configuração descreve os métodos usados para garantir que os sistemas e dispositivos dentro da rede de uma organização sigam as configurações de segurança obrigatórias. A imposição da configuração geralmente depende de alguns recursos importantes.

- Os **parâmetros de referência padronizados para configurações** (Standardized Configuration Baselines) são definidos por organizações como NIST, CIS ou a própria organização cliente e usados como referência para determinar como os sistemas e dispositivos devem ser configurados.
- São usadas **ferramentas de gerenciamento de configuração automatizada (Automated Configuration Management Tools)** para aplicar e manter automaticamente os parâmetros de referência padronizados para as configurações em todo o ambiente.
- O **monitoramento contínuo e as verificações de conformidade** são cruciais para detectar desvios das configurações obrigatórias.
- Os processos de **gerenciamento de mudanças (Change Management)** garantem que as mudanças de configuração sejam devidamente avaliadas, testadas e aprovadas antes da implementação.

O gerenciamento de regras de firewall na rede de uma organização é um exemplo prático de uma configuração que pode se beneficiar da imposição de configuração. Uma organização pode usar uma ferramenta de gerenciamento de configuração automatizada para garantir que os firewalls do dispositivo estejam configurados corretamente, incluindo o bloqueio de todo o tráfego de entrada por padrão e a permissão apenas de conexões específicas e necessárias. O monitoramento contínuo detecta quaisquer alterações e as reverte automaticamente para impor a configuração segura aprovada.

Além disso, as verificações regulares de conformidade garantem que os firewalls sigam as configurações aprovadas, e quaisquer mudanças precisam ser revisadas e aprovadas por meio de processos adequados de gerenciamento de mudanças antes da implementação.

Política de grupo

Política de grupo (Group Policy) é um recurso do sistema operacional Microsoft Windows que fornece gerenciamento e configuração centralizados de sistemas operacionais, aplicativos e configurações do usuário em um ambiente do Active Directory. As Políticas de grupo impõem configurações de segurança, como aquelas determinadas por um parâmetro de referência, aplicando configurações consistentes em todos os sistemas vinculados a Políticas de grupo específicas. Em termos gerais, as Políticas de grupo são vinculadas a contêineres chamados Unidades organizacionais (Organizational Units, OU) que normalmente contêm objetos do usuário e do computador. As Políticas de grupo vinculadas à UO se aplicam a todos os objetos contidos nela.

Exemplos de configurações comuns de Política de grupo incluem políticas de senha, direitos do usuário, configurações do Firewall do Windows, configurações de atualização do sistema, restrições de instalação de software e muitos outros.

A aplicação central de configurações usando a Política de grupo reduz possíveis problemas relacionados a configurações incorretas ou inconsistentes.

SELinux

O [SELinux] é um recurso de segurança do kernel Linux que oferece suporte a políticas de controle de acesso, incluindo controles de acesso mandatórios (MAC). O SELinux permite um controle de permissão mais granular sobre cada processo e objeto do sistema dentro de um sistema operacional, limitando estritamente os recursos que um processo pode acessar e quais operações pode executar. O SELinux opera com base no princípio de que, se um processo ou usuário não precisa de acesso a recursos para operar, ele será bloqueado para isolar melhor os aplicativos, restringir o acesso ao sistema e aos arquivos e impedir que programas mal-intencionados ou defeituosos causem danos ao sistema. Os recursos do SELinux também estão disponíveis no sistema operacional Android: <https://source.android.com/docs/security/features/selinux> (<https://source.android.com/docs/security/features/selinux>). Devido às diferenças significativas de arquitetura entre o Linux e o Android, o recurso SELinux no Android é possibilitado usando o SEAndroid para fornecer funcionalidade semelhante, mas usando uma base de código mantida separadamente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo: se a segurança do endpoint for comprometida, autentique por onde ocorreu essa vulnerabilidade. Se foi por um usuário, software, equipamento shadow IT ou por algum dispositivo móvel. Para cada porta dessa de onde o invasor entrou ou o vírus se espalhou, tem uma tratativa e orientação para cada um deles.

Esse capítulo é extremamente extenso, me perdi até em alguns conceitos só de ler. Logo após é falado sobre um pouco de controles de acessos e permissões. Um deles que é citado em quase todo caso quando entramos nesse assunto é o tal do ACL (Access Control Lists) que nada mais é uma política de grupo onde o usuário pode ou não receber alguma coisa por autorização, políticas de controles de acesso.

Nos é explicado o funcionamento básico de permissões em arquivos e configurações seguras para a realização delas.

No Linux foi explicado sobre os comandos `chmod` que dá permissões a arquivos. São dados através de letras ou números de são notações octal onde são explicados que 755 só pode ser a soma de algumas letras para certas permissões.

Também foram citados listas de permissões e bloqueios de aplicativos, onde existem dois tipos de listas a allow list que é a lista de permissão e a block lista que é a lista de bloqueios.

Ambas parecem ser a mesma coisa, mas não são. Logo mais falamos sobre monitoramento e auditoria na infraestrutura. Se aplicamos uma regra que foi efetiva, no futuro, ela pode estar sujeita a mudanças e precisa ser auditada novamente, por isso o constante monitoramento das regras para ver se estão funcionando de acordo.

Imposição de configurações são efetivas quando sigas alguns padrões já feitos, por exemplo o do NIST, CIS ou a própria organização cliente para determinar quais sistemas devem ser padronizados e configurados. Ferramentas para padronização são usadas para deixar o ambiente sempre seguro e auditado, para isso, são usadas ferramentas automatizadas. O monitoramento contínuo e verificações de conformidade são sempre importantes para detectar avarias dentro da rede, coisas que eram para ser obrigatórias e não são. Gerenciamento de mudanças são feitos e testados antes de realizar a implementação na rede.

Diferentes abordagens são necessárias para fortalecer e proteger (hardening) os endpoints em resposta a ameaças de cibersegurança variadas e em constante evolução. Essas ameaças exigem uma estratégia de defesa abrangente e em camadas que aborde as vulnerabilidades em vários níveis, desde o acesso físico até protocolos de rede, configurações do sistema operacional e comportamentos do usuário.

Proteger as portas

O fortalecimento e hardening de portas de dispositivos físicos envolve restringir as interfaces físicas em um dispositivo que podem ser usadas para se conectar a ele, reduzindo assim possíveis vias de ataque físico. Uma técnica comum é desativar portas físicas desnecessárias, como USB, HDMI ou portas seriais, quando não atendem aos fins comerciais. Isso ajuda a evitar a transferência não autorizada de dados, a instalação de software mal-intencionado ou o acesso direto a um sistema.

Os softwares de controle de portas fornecem proteção adicional ao permitir que apenas dispositivos autorizados se conectem por meio de portas físicas com base em identificadores de dispositivos. Por exemplo, eles podem bloquear todos os dispositivos USB de armazenamento em massa exceto os aprovados pela empresa.

Os analistas de segurança podem aproveitar as configurações no firmware do dispositivo ou no UEFI/BIOS para fortalecimento e hardening de portas para desativar as portas físicas ou para exigir uma senha antes que um dispositivo possa ser inicializado a partir de uma fonte não padrão, como uma unidade USB. Para dispositivos como tablets e notebooks que dependem de protocolos wireless, a desativação do recurso de conexão automática à rede pode impedir que o dispositivo use redes potencialmente inseguras ou nocivas.

Como revelado pelo pesquisador Karsten Nohl em seu artigo BadUSB, a exploração do firmware de dispositivos de armazenamento externo, como pen drives USB e até mesmo cabos de carregamento que aparentam ser comuns, fornece aos atacantes um vasto arsenal de ferramentas. O firmware pode ser reprogramado para fazer com que o dispositivo se pareça com outra classe de dispositivo, como um teclado. Nesse caso, ele pode ser usado para injetar uma série de pressionamentos de teclas em um anexo ou funcionar como um keylogger (<https://www.fortinet.com/br/resources/cyberglossary/what-is-keyloggers>). O dispositivo também pode ser programado para agir como um dispositivo de rede e corromper a resolução de nomes, redirecionando o usuário para sites mal-intencionados.

Outro exemplo é o cabo O.MG (theverge.com/2019/8/15/20807854/apple-mac-lightning-cable-hack-mike-grover-mg-omg-cables-defcon-cybersecurity (<https://www.theverge.com/2019/8/15/20807854/apple-mac-lightning-cable-hack-mike-grover-mg-omg-cables-defcon-cybersecurity>)), que contém capacidade de processamento suficiente em um cabo USB-Lightning de aparência comum para executar um access point e um keylogger.

Um dispositivo modificado pode ter pistas visuais que o distinguem de um pen drive ou cabo fabricado em massa, mas elas podem ser difíceis de detectar. Você deve alertar os usuários sobre os riscos e repetir o conselho de nunca conectar dispositivos de origem desconhecida a seus computadores e smartphones. Se você suspeitar que um dispositivo é um vetor de ataque, observe atentamente um sistema de laboratório em sandbox (às vezes chamado de sheep dip ([https://en-wikipedia-org.translate.goog/wiki/Sheep_dip_\(computing\)?_x_tr_sl=en&_x_tr_tl=pt&_x_tr_hl=pt&_x_tr_pto=tc](https://en-wikipedia-org.translate.goog/wiki/Sheep_dip_(computing)?_x_tr_sl=en&_x_tr_tl=pt&_x_tr_hl=pt&_x_tr_pto=tc))) ao conectar o dispositivo. Preste atenção a quaisquer janelas ou processos de prompt de comando, como a inicialização do interpretador de comandos e alterações no registro ou em outros arquivos do sistema.

resumo: a proteção de portas físicas da máquina é essencial para uma processo de hardening para um hardware. Como foi citado acima, diversas opções são viáveis para um atacante pela porta USB, seja ela uma porta desprotegida e um malware invadir a máquina por um simples pen drive ou então um dispositivo que simula a entrada de um dispositivo comum, por exemplo envia comandos a máquina dizendo que é um teclado, no caso do cabo de carregador O.MG. Para descontaminação de mídias removíveis, recomendasse fazer uma procedimento chamado sheep dip, um banho de ovelha para limpar todo tipo de sujeira encontrada neles.

Nota:

Nem todos os ataques serão muito obscuros. Os pendrives infectados com malware comum ainda são vetores de infecção incrivelmente prolíficos. Os hosts devem sempre ser configurados para evitar a execução automática quando forem conectados dispositivos USB. As portas USB podem ser bloqueadas completamente usando a maioria dos tipos de sistemas de detecção de intrusão de host (Host Intrusion Detection Systems, HIDS).

Proteja as portas lógicas implementando medidas para proteger e controlar o acesso a portas em um sistema de computador ou rede. As portas lógicas são recursos de comunicação baseados em software que permitem a troca de dados entre aplicativos ou serviços. Exemplos comuns de portas lógicas incluem as portas conhecidas usadas pelos protocolos TCP/IP e UDP.

Os firewalls protegem as portas lógicas examinando o tráfego de rede e aplicando políticas de segurança para permitir ou bloquear conexões específicas com base em números de porta, endereços de origem e destino e protocolos. As práticas de fortalecimento e hardening de serviços garantem que os serviços em execução em portas lógicas sejam protegidos contra ameaças à segurança. Alguns exemplos são manter o software atualizado e desativar serviços desnecessários.

Técnicas de criptografia

A criptografia de endpoint é fundamental para proteger dados confidenciais, especialmente em ambientes corporativos. Várias abordagens diferentes são necessárias para proteger os dados nos endpoints. Algumas das importantes são:

- **Full Disk Encryption (FDE) (criptografia do disco completo)**, que criptografa todo o disco rígido de um dispositivo. Isso garante que todos os dados, incluindo o sistema operacional e os arquivos do usuário, sejam protegidos mesmo quando o sistema operacional não estiver em execução. Ferramentas como o BitLocker para Windows e o FileVault para macOS fornecem recursos de criptografia de disco completo.
- **Criptografia de mídia removível**, que garante que os dados permaneçam protegidos mesmo quando removidos fisicamente de dispositivos como SD Cards ou USB de armazenamento em massa. Muitas ferramentas de FDE

também incluem opções para criptografar mídia removível.

- As **Virtual Private Networks (VPNs) (redes virtuais privadas)** complementam a criptografia do endpoint, fornecendo um túnel seguro para transmissão de dados que protege contra ataques de eavesdropping (interceptação), on-path e muitos outros tipos.
- A **criptografia de e-mail** protege informações confidenciais armazenadas em e-mails usando protocolos como PGP (Pretty Good Privacy) ou S/MIME (Secure/Multipurpose Internet Mail Extensions).

Firewalls baseados em host e IPS

[[Firewalls baseados em host]] e sistemas de prevenção de intrusões (IPS) são elementos fundamentais do hardening de endpoints, pois oferecem controles para o tráfego de rede de entrada e saída e são essenciais para a detecção de possíveis ataques. Uma técnica importante para usá-los ao proteger (hardening) endpoints envolve a implementação de políticas de negação padrão para bloquear todo o tráfego, a menos que explicitamente permitido. Essa tática garante que apenas serviços e aplicativos aprovados possam se comunicar. A configuração de firewalls para bloquear ou permitir o tráfego com base nos números das portas também é fundamental para minimizar os pontos de entrada para o ataque. A filtragem de tráfego permite que os firewalls e IPS analisem o tráfego com base em parâmetros como endereços de IP, protocolos e serviços para bloquear tráfego mal-intencionado ou permitir que o tráfego use apenas protocolos seguros.

Uma das funções de um IPS é detectar e prevenir intrusões monitorando padrões mal-intencionados conhecidos ou anomalias no tráfego de rede. Firewalls avançados baseados em host geralmente incluem recursos de controle de aplicativos que permitem que apenas aplicativos confiáveis se comuniquem. Os logs gerados por firewalls baseados em host e IPS suportam detecção e resposta rápidas quando integrados a outras ferramentas de segurança, como sistemas de gerenciamento de eventos e informações de segurança (SIEM) (<https://www.ibm.com/br-pt/think/topics/siem>).

Instalação de proteção de endpoint

Para garantir a máxima proteção e gerenciamento eficiente, a implantação e o gerenciamento de agentes de proteção de endpoint em estações de trabalho, notebooks e servidores em um ambiente corporativo exigem planejamento estratégico e adesão às práticas estabelecidas de configuração e o gerenciamento de melhores práticas.

- **Crie um plano de implantação** com considerações como a ordem de implantação (quais dispositivos ou departamentos devem receber agentes primeiro), prazos e estágios de aproveitamento para limitar possíveis interrupções causadas pelas configurações de proteção do endpoint.
- **Padronize as configurações** de proteção de endpoint em todos os dispositivos para garantir consistência nos níveis de proteção e simplificar o gerenciamento de conformidade.
- **Automatize implantações** usando ferramentas como o System Center Configuration Manager (SCCM) da Microsoft, Políticas de grupo ou soluções de terceiros para economizar tempo, melhorar a consistência e reduzir o risco de erro humano.
- **Atualizações e patches** no software do agente de proteção de endpoint e definições são necessários para garantir os mais altos níveis de proteção contra as ameaças conhecidas mais recentes.
- **Monitore** os agentes de proteção de endpoint para identificar alertas ou sinais de possíveis incidentes de segurança, verificar se os agentes estão em execução e garantir que as atualizações e os patches sejam

aplicados com sucesso.

- **Centralize o gerenciamento** para fornecer uma visão abrangente das configurações, atualizações e status do endpoint. O gerenciamento centralizado também permite que os administradores imponham políticas de segurança globais.

Alteração de padrões e remoção de softwares desnecessários

A alteração de senhas padrão e a remoção de softwares desnecessários são duas práticas fundamentais no hardening de um endpoint para fortalecer sua postura de segurança. As senhas padrão, geralmente definidas pelos fabricantes, são amplamente conhecidas e facilmente detectáveis, tornando os dispositivos que as usam particularmente vulneráveis a acesso não autorizado. Portanto, a alteração dessas senhas por credenciais fortes e exclusivas é crucial como parte do processo de configuração inicial de qualquer dispositivo ou sistema.

A remoção de software desnecessário é outra etapa crítica ao fazer o hardening de um endpoint. Cada aplicativo de software apresenta possíveis vulnerabilidades que agentes mal-intencionados podem explorar. A superfície de ataque é significativamente diminuída pela redução do número de aplicativos de software para apenas aqueles necessários para a função pretendida do dispositivo. Isso inclui a remoção de aplicativos desnecessários, mas também a desativação de recursos ou serviços desnecessários nos aplicativos restantes. Essa prática simplifica o processo de manutenção e gerenciamento de patches porque há menos aplicativos para atualizar, reduzindo as chances de perder um patch de segurança crítico.

Uma impressora de rede multifuncional de nível empresarial apresenta diversas vulnerabilidades de segurança possíveis se não for gerenciada de forma adequada. Esses dispositivos complexos geralmente vêm com senhas padrão definidas pelo fabricante destinadas à configuração inicial e acesso administrativo, e elas são, de modo geral, amplamente conhecidas e facilmente acessíveis. A alteração dessas senhas imediatamente após a instalação e o uso de senhas exclusivas e fortes é fundamental. As impressoras multifuncionais geralmente possuem uma ampla gama de recursos. Recursos que não são explicitamente necessários no ambiente, como recursos de impressão em nuvem, recursos de email ou interfaces de servidor da Web, devem ser desativados para minimizar possíveis vetores de ataque.

As atualizações regulares de firmware do fabricante são cruciais para corrigir quaisquer vulnerabilidades conhecidas em versões de firmware mais antigas, fortalecendo a segurança da impressora. Se possível, utilize protocolos de rede criptografados, como HTTPS para interfaces da Web e SNMPv3 para gerenciamento de dispositivos, para proteger os dados, incluindo senhas, por meio de protocolos não criptografados. O acesso à impressora deve ser baseado no princípio do privilégio mínimo, concedendo apenas o acesso necessário para tarefas específicas.

Desativação

Os processos de desativação desempenham um papel vital no apoio à segurança dentro de uma organização. Quando um dispositivo não é mais necessário, ele geralmente contém dados residuais, informações potencialmente confidenciais e configurações do sistema que podem ser exploradas. Um processo de desativação completo e sistemático garante que todos os dados sejam apagados ou substituídos com segurança para reduzir o risco de

exposição. A desativação também envolve a redefinição dos dispositivos para as configurações de fábrica e a eliminação de quaisquer configurações residuais. A atualização dos registros de inventário durante a desativação também é importante para manter um registro preciso dos ativos e auxiliar nos requisitos de conformidade que exigem o rastreamento preciso dos ativos e o descarte seguro.

A desativação de hardware com segurança é essencial, pois o hardware geralmente armazena dados confidenciais em unidades internas e retém dados de configuração e do usuário potencialmente exploráveis. A limpeza dos dados é uma etapa extremamente importante no processo de desmobilização e descreve como todos os dados no dispositivo ou na mídia removível são apagados com segurança para garantir que nenhum dado recuperável permaneça lá.

Além disso, o dispositivo deve ser redefinido para as configurações de fábrica por meio de um console de gerenciamento ou outra aplicação, eliminando quaisquer configurações ou definições residuais do sistema que possam representar um risco à segurança. O descarte de equipamentos físicos geralmente garante a destruição física de alguns componentes internos, como módulos de memória, unidades de disco rígido (HDD), discos de estado sólido (SSD), M.2 ou outros módulos de armazenamento, especialmente se eles armazenaram dados confidenciais. Em alguns cenários, um serviço de descarte profissional especializado em descarte seguro certificado de componentes eletrônicos pode ser a escolha mais apropriada.

A etapa final do processo de desativação envolve a documentação e a atualização dos registros de inventário para refletir que o dispositivo foi desativado. Essa etapa garante um registro preciso dos ativos e a conformidade com os padrões e regulamentos de segurança.

Nota:

Por exemplo, as etapas para a desativação de uma impressora multifuncional de rede incluem a limpeza de trabalhos de impressão armazenados, documentos digitalizados e (potencialmente) transmissões de fax; a limpeza de credenciais de rede armazenadas e dados de configuração; a redefinição completa para o padrão de fábrica; o descarte ou a destruição segura de componentes físicos; e atualizações no inventário de ativos para refletir o status do dispositivo.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os sistemas de controle industrial (Industrial Control Systems, ICS), incluindo sistemas de controle de supervisão e aquisição de dados (Supervisory Control and Data Acquisition, SCADA), sistemas integrados, sistemas operacionais em tempo real (Real-Time Operating Systems, RTOS) e dispositivos de Internet das coisas (Internet of Things, IoT), têm sido alvo de ataques com mais frequência nos últimos anos devido ao seu papel vital no controle de infraestruturas críticas.

Aplicam-se a esses sistemas estratégias gerais de fortalecimento e hardening, incluindo controles comuns, como atualizações regulares do sistema, desativação de serviços desnecessários, limitação do acesso à rede, uso de credenciais seguras e uso de controles de acesso baseados em função. A segurança em nível de rede também deve ser implementada para protegê-los, como firewalls, IDS/IPS, protocolos de criptografia de transporte, como TLS e SSH, auditorias regulares de segurança e testes de penetração para ajudar a identificar e remediar vulnerabilidades.

Hardening de ICS/SCADA

Para os sistemas de ICS/SCADA, o hardening envolve uma segmentação de rede rigorosa para isolar esses sistemas da rede mais ampla e processos robustos de autenticação e autorização para limitar estritamente o acesso ao sistema.

O ICS/SCADA é frequentemente usado para controlar operações físicas.

Garantir a proteção contra ameaças cibernéticas e físicas é mais crucial porque as violações podem resultar em desastres ambientais, falhas em serviços públicos de energia/gás/água e perda de vidas. Um controle exclusivo frequentemente usado para proteger o ICS/SCADA são os gateways unidirecionais (ou diodos de dados)

([https://waterfall--security-com.translate.googleusercontent.com/translate/gdata-diode-and-unidirectional-gateways/?](https://waterfall--security-com.translate.googleusercontent.com/translate/gdata-diode-and-unidirectional-gateways/?x_tr_sl=en&x_tr_tl=pt&x_tr_hl=pt&x_tr_pto=tc)

[x_tr_sl=en&x_tr_tl=pt&x_tr_hl=pt&x_tr_pto=tc](https://waterfall--security-com.translate.googleusercontent.com/translate/gdata-diode-and-unidirectional-gateways/?x_tr_sl=en&x_tr_tl=pt&x_tr_hl=pt&x_tr_pto=tc)), que garantem que os dados fluam apenas para fora desses sistemas, protegendo-os contra ataques de entrada.

Hardening de sistemas integrados e RTOS

Devido aos seus recursos limitados, sistemas integrados simples e RTOS normalmente não oferecem suporte a medidas de segurança tradicionais. O ideal é que a segurança seja projetada para esses sistemas desde o início, considerando aspectos como práticas de codificação seguras, design mínimo (onde o sistema tem apenas os recursos necessários para executar sua função), mecanismos de inicialização segura, proteção contra violações físicas e testes de segurança abrangentes.

A organização deve selecionar dispositivos com base em recursos e qualidade de segurança, em vez de se concentrar apenas em recursos de usabilidade e custos. Os dispositivos da IoT apresentam desafios de hardening semelhantes aos descritos anteriormente, mas também incluem problemas significativos de privacidade. Em última análise, cada tipo de dispositivo requer uma abordagem cuidadosamente adaptada para o seu fortalecimento e hardening.

Os padrões de segurança e as certificações desempenham um papel significativo na segurança e integridade dos sistemas operacionais em tempo real (Real-Time Operating Systems, RTOS) e sistemas integrados, fornecendo diretrizes, práticas recomendadas e benchmarks para projetar, implementar e avaliar a segurança desses sistemas. Os padrões de segurança definem requisitos, controles e procedimentos relevantes para RTOS e sistemas integrados e incluem “Common Criteria” (critérios comuns) (ISO/IEC 15408), IEC 62443, MISRA-C e padrões de codificação segura CERT. As certificações demonstram conformidade com padrões de segurança específicos, garantem que um sistema ou produto atenda aos requisitos de segurança preestabelecidos e incluem ISO 27001, IEC 61508 e outros.

Os padrões de segurança e as certificações ajudam a estabelecer uma estrutura para avaliar, implementar e validar controles de segurança em RTOS e sistemas integrados. Eles definem linguagem e critérios comuns para avaliar a segurança desses sistemas e garantem confiança em seus recursos de segurança.

Nota:

Consulte mais informações em Common Criteria: <https://www.commoncriteriaportal.org>
(<https://www.commoncriteriaportal.org>).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A proteção (hardening) de dispositivos móveis é fundamental para a segurança cibernética e inclui várias práticas essenciais criadas para proteger os dispositivos contra ameaças e vulnerabilidades, o que inclui (no mínimo) controles como atualizações regulares, restrições de acesso, configurações seguras, criptografia, bloqueio de tela, controles de acesso à rede, restrições de aplicativos, limitação de certos recursos (p.ex. Bluetooth e NFC) e aproveitamento de soluções de gerenciamento de dispositivos móveis (MDM) para centralizar o gerenciamento e garantir a conformidade do dispositivo.

Objetivos abordados no exame:

- 4.1 Considerando determinado cenário, aplicar técnicas de segurança comuns aos recursos de computação.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Há muitas semelhanças entre o processo de hardening de dispositivos móveis e de computadores tradicionais. Ambos exigem patches do sistema operacional; senhas fortes e exclusivas; software de proteção de endpoints; o princípio do privilégio mínimo e outros controles semelhantes.

No entanto, também existem diferenças baseadas nos recursos especiais que estão disponíveis nos dispositivos móveis. Por exemplo, os dispositivos móveis são mais propensos à perda física ou a roubos, o que aumenta a importância dos recursos de limpeza remota, criptografia e telas de bloqueio seguras.

O ecossistema de aplicativos móveis abrange muitos aplicativos com diferentes requisitos de permissão de acesso que apresentam desafios exclusivos de privacidade e proteção de dados. Em comparação aos computadores tradicionais, os dispositivos móveis geralmente possuem GPS, Bluetooth e suporte a NFC, o que abre caminhos adicionais para ataques caso não sejam devidamente gerenciados.

Modelos de implantação

Os modelos de implantação de dispositivos móveis são fundamentais para definir como uma organização usa, gerencia e protege os dispositivos. O modelo de implantação escolhido afeta tudo, desde a experiência do usuário até o nível de controle da organização sobre o dispositivo.

- **[[Bring Your Own Device (BYOD)]]**: significa que o dispositivo móvel é de propriedade do colaborador. O dispositivo deve estar em conformidade com os requisitos estipulados pela organização (como a versão do sistema operacional e os recursos do dispositivo), e o funcionário deve concordar em ter aplicativos corporativos instalados e reconhecer o direito da organização de realizar verificações de auditoria e conformidade dentro dos limites das regras legais e regulatórias. Esse modelo é popular entre os funcionários, mas representa um risco significativo para as operações de segurança.
- **[[Corporate Owned, Business Only (COBO)]]**: significa que o dispositivo é de propriedade da organização e pode ser utilizado apenas para fins corporativos.
- **[[Corporate Owned, Personally Enabled (COPE)]]**: significa que o dispositivo é escolhido e fornecido pela organização, permanecendo como propriedade da empresa. O funcionário pode usá-lo para acessar contas pessoais de email, redes sociais e para navegação pessoal na web (sujeito aos requisitos das políticas de uso aceitável estabelecidas).
- **[[Choose Your Own Device (CYOD)]]**: é semelhante ao COPE, exceto pelo fato de que o colaborador pode escolher o dispositivo a partir de uma lista previamente estabelecida.

Modelos como traga seu próprio dispositivo (BYOD), escolha seu próprio dispositivo (CYOD) e propriedade corporativa, uso pessoal (COPE) oferecem graus de controle variados e flexibilidade tanto para a organização quanto para o funcionário. Por exemplo, o BYOD pode proporcionar economia com equipamentos para a organização e flexibilidade para os funcionários, mas também apresenta desafios de segurança causados pela mistura de dados pessoais e profissionais. Por outro lado, o COPE possibilita à organização maior controle sobre o dispositivo, o que melhora a segurança, mas requer mais gastos com equipamentos.

A seleção do modelo adequado de implantação de dispositivos móveis é vital para equilibrar de forma eficaz a produtividade, a satisfação do usuário, a eficiência de custos e a segurança no local de trabalho.

Gerenciamento de dispositivos móveis

O [[gerenciamento de dispositivos móveis (MDM)]] é uma estratégia fundamental utilizada pelos departamentos de TI para gerenciar, proteger e aplicar políticas em smartphones, tablets e outros endpoints. A importância do MDM cresceu significativamente devido ao aumento da popularidade do trabalho remoto e das políticas de traga seu próprio dispositivo (BYOD). A funcionalidade do MDM é ampla e inclui recursos sofisticados de gerenciamento de segurança, o que o torna uma ferramenta essencial no gerenciamento da TI corporativa. O MDM permite que os departamentos de TI mantenham um inventário de todos os dispositivos móveis que acessam os recursos corporativos e ajuda a garantir que apenas os dispositivos autorizados mantenham o acesso. Além disso, o MDM pode impor políticas de segurança, como a criptografia de dispositivo obrigatória ou a exigência de bloqueio de tela. O MDM pode ativar remotamente os recursos de bloqueio ou limpeza para proteger dados confidenciais em caso de perda ou roubo de um dispositivo.

Ele ajuda a centralizar e aplicar configurações de hardening dos dispositivos e pode reduzir vulnerabilidades por meio de controles padrão, como a desativação de recursos ou serviços desnecessários, a aplicação de recursos de segurança e a restrição de instalações de aplicativos. O MDM também pode gerenciar atualizações e patches de dispositivos para garantir que estejam protegidos contra vulnerabilidades conhecidas e colocar em quarentena ou remover dispositivos que não atendam aos requisitos de segurança.

Algumas tarefas comuns gerenciadas pelo MDM incluem distribuir e atualizar aplicativos corporativos, gerenciar contas de email corporativas, gerenciar o rastreamento e a delimitação geográficos de dispositivos, gerenciar a lista de permissões ou bloqueios de aplicativos, controlar o acesso ou uso da Internet e muitos outros recursos. Várias plataformas populares de MDM estão disponíveis no mercado no momento em que este texto foi escrito. A solução MDM da Apple é integrada aos seus sistemas operacionais, o que permite o gerenciamento de Macs, iPhones e iPads. O Google tem uma solução equivalente para dispositivos Android conhecida como Android Enterprise. As soluções independentes incluem plataformas como Microsoft Intune, VMware AirWatch e IBM MaaS360. As soluções independentes de plataforma fornecem recursos e capacidades abrangentes para atender a diversas necessidades, mas podem ser complicadas e caras de implementar e gerenciar.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Todas as versões de sistemas operacionais para smartphones e tablets, exceto as mais antigas, oferecem criptografia completa do dispositivo. No iOS, existem vários níveis de criptografia.

- Todos os dados do usuário no dispositivo são sempre criptografados, mas a chave é armazenada no dispositivo. Isso é usado principalmente como meio de limpeza do dispositivo. Basta o sistema operacional excluir a chave para tornar os dados inacessíveis; ele não precisa limpar cada local de armazenamento).

- Os dados de email e aplicativos que usam a opção “Proteção de dados” estão sujeitos a uma segunda criptografia usando uma chave derivada e protegida pela credencial do usuário. Isso proporciona segurança dos dados, caso o dispositivo seja roubado. Nem todos os dados do usuário são criptografados usando a opção “Proteção de dados”. Contatos, mensagens SMS e fotos não são, por exemplo.

No iOS, a criptografia da Proteção de dados é ativada automaticamente quando você configura um bloqueio por senha no dispositivo. No Android, há diferenças substanciais nas opções de criptografia entre as versões(source.android.com/security/encryption (<https://source.android.com/security/encryption>)). A partir do Android 10, não há criptografia de disco completa, pois é considerada prejudicial demais para o desempenho. Os dados do usuário são criptografados por padrão no arquivo.

Um dispositivo móvel contém uma unidade de estado sólido (memória flash) para armazenamento de longo prazo de aplicativos e dados. Alguns aparelhos Android oferecem suporte para armazenamento removível usando mídia externa, como um slot para cartão Micro Secure Digital (SD). Alguns podem ser compatíveis com a conexão de dispositivos de armazenamento baseados em USB. O software de criptografia do sistema operacional móvel também pode permitir a criptografia do armazenamento removível, mas isso nem sempre é o caso. É necessário ter o cuidado de aplicar a criptografia a cartões de armazenamento usando software de terceiros, se necessário, e limitar o armazenamento de dados confidenciais neles.

Um MicroSD HSM é um pequeno módulo de segurança de hardware de fator de forma criado para armazenar chaves criptográficas com segurança. Isso permite que o material criptográfico seja usado com diferentes dispositivos, como um notebook e um smartphone.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A geolocalização é o uso de atributos da rede para identificar (ou estimar) a posição física de um dispositivo. O dispositivo usa serviços de localização para determinar sua posição atual. Os serviços de localização podem usar dois sistemas:

- **Global Positioning System (GPS):** é um meio de determinar a latitude e longitude do dispositivo com base em informações recebidas de satélites por meio de um sensor GPS.
- **[[Indoor Positioning System (IPS)]]:** determina a localização de um dispositivo triangulando sua proximidade com outras fontes de rádio, como torres de telefonia celular, pontos de acesso Wi-Fi e beacons Bluetooth/RFID.

Os serviços de localização ficam disponíveis para qualquer aplicativo ao qual o usuário tenha concedido permissão para utilizá-los.

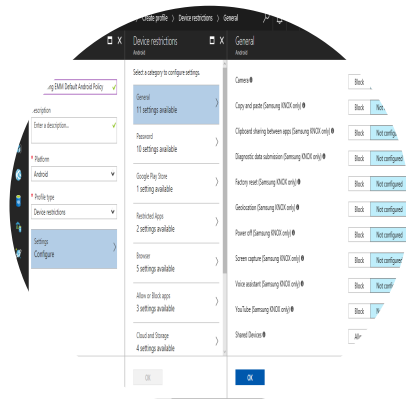
A principal preocupação relacionada aos serviços de localização é a privacidade. Embora seja muito útil para mapas e navegação guiada, os serviços de localização fornecem um mecanismo para rastrear os movimentos de um indivíduo e, portanto, seus hábitos sociais e comerciais. O problema é ainda mais agravado pela infinidade de aplicativos móveis que exigem acesso aos serviços de localização e, em seguida, enviam as informações para os desenvolvedores do aplicativo e as armazenam na estrutura de arquivos do dispositivo. Se um invasor conseguir obter acesso a esses dados, então o stalking, a engenharia social e até mesmo o roubo de identidade se tornam possibilidades concretas.

Delimitação geográfica e aplicação de restrições a câmeras e microfones

[[Geofencing]] é a prática de criar um perímetro virtual com base na geografia do mundo real. A delimitação geográfica pode ser uma ferramenta útil no que diz respeito ao controle do uso das funções de câmera ou vídeo ou à aplicação de autenticação com reconhecimento de contexto.

Uma organização pode usar a delimitação geográfica para criar um perímetro ao redor de suas instalações e, posteriormente, limitar a funcionalidade dos dispositivos que excedam esse limite. Um smartphone desbloqueado pode ser bloqueado e forçado a se autenticar novamente ao entrar nas instalações, e a câmera e o microfone podem ser desativados. A posição do dispositivo é obtida dos serviços de localização.

Figura 1. Restrição das permissões do dispositivo, como câmera e captura de tela, usando o Intune.



Captura de tela usada com permissão da Microsoft.

Descrição

A tela está dividida em três janelas verticais. A primeira janela está intitulada “criar perfil”. Ela contém campos para preencher o nome, descrição, plataforma e tipo de perfil. A opção configurar em configurações está selecionada para abrir a próxima janela. Um botão criar está localizado na parte inferior. A segunda janela está intitulada restrições de dispositivo, Android. Ele lista as categorias para configurar as definições. A opção Geral, 11 configurações disponíveis, está selecionada para abrir a próxima janela, Geral, Android. Esta janela exibe várias opções. Cada opção possui dois botões: bloquear e não configurado. O botão OK está presente no canto inferior direito.

Marcação por GPS (GPS tagging)

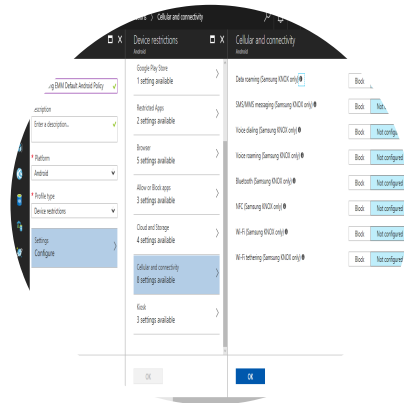
A marcação por GPS é o processo de adicionar metadados de identificação geográfica, como a latitude e a longitude em que o dispositivo estava localizado no momento, a mídias como fotografias, mensagens SMS, vídeo etc. Isso permite que o aplicativo associe a mídia a coordenadas específicas de latitude e longitude. A marcação por GPS são informações pessoais altamente confidenciais e dados organizacionais potencialmente confidenciais. As fotos marcadas com GPS enviadas para as redes sociais podem ser usadas para rastrear os movimentos e a localização de uma pessoa. Por exemplo, um soldado russo revelou as posições das tropas ao publicar selfies marcadas com GPS no Instagram (arstechnica.com/tech-policy/2014/08/opposite-of-opsec-russian-soldier-posts-selfies-from-inside-ukraine (<https://arstechnica.com/tech-policy/2014/08/opposite-of-opsec-russian-soldier-posts-selfies-from-inside-ukraine/>)).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os dispositivos móveis usam diversos métodos de conexão para estabelecer comunicações em redes locais e pessoais e para acesso a dados da Internet por meio de provedores de serviços.

Figura 1. Bloqueio dos métodos de conectividade do Android com o Intune: observe que a maioria das configurações só pode ser aplicada a dispositivos compatíveis com o Samsung KNOX.



Captura de tela usada com permissão da Microsoft.

Descrição

A tela está dividida em três janelas verticais. A primeira janela está intitulada “criar perfil”. Ela contém campos para preencher o nome, descrição, plataforma e tipo de perfil. A opção configurar em configurações está selecionada para abrir a próxima janela. Um botão criar está localizado na parte inferior. A segunda janela está intitulada restrições de dispositivo, Android. A opção celular e conectividade, 8 configurações disponíveis, está selecionada para abrir a próxima janela, celular e conectividade, Android. Esta janela exibe várias opções. Cada opção possui dois botões: bloquear e não configurado. O botão OK está presente no canto inferior direito.

Conexões de dados de celular/móveis

Os smartphones, tablets e notebooks usam redes de dados móveis para a comunicação de dados. É improvável que as conexões de dados móveis estejam sujeitas a monitoramento e filtragem.

A proteção das conexões de dados [[celulares]] exige a implementação de diversos controles nos endpoints para garantir a segurança e a privacidade dos dados corporativos transmitidos por redes celulares, uma vez que a comunicação de dados móveis, na prática, contorna as proteções de rede implementadas no ambiente corporativo. As tecnologias que protegem as conexões de dados de celular incluem a conscientização e o treinamento do usuário, redes virtuais privadas (VPN), gerenciamento de dispositivos móveis (MDM), defesa contra ameaças móveis e prevenção contra perda de dados (DLP).

Sistema de posicionamento global (GPS)

Um sensor de [[sistema global de posicionamento (GPS)]] determina a posição do dispositivo por meio de trilateração, utilizando sinais de satélites GPS em órbita. Como esse cálculo pode ser lento, a maioria dos smartphones usa o GPS assistido (A-GPS) para obter coordenadas da torre de celular mais próxima e ajustar a posição do dispositivo em relação à torre. O A-GPS usa dados de celular. Os satélites GPS são operados pelo governo dos Estados Unidos. Alguns sensores GPS podem utilizar sinais de outros satélites operados pela União Europeia (Galileo), Rússia (GLONASS) ou China (BeiDou).

Os sinais de GPS podem ser bloqueados ou até mesmo falsificados usando equipamentos de rádio especializados. Isso pode ser utilizado, por exemplo, para burlar mecanismos de geofencing.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os dispositivos móveis geralmente são configurados para usar uma conexão Wi-Fi para dados, se estiver disponível. Se o usuário estabelecer uma conexão com uma rede corporativa que usa uma forte segurança WPA3, há um risco bastante baixo de espionagem ou de ataques de invasores intermediários. Os riscos do Wi-Fi vêm de usuários que se conectam a access points abertos ou possivelmente a um access point mal-intencionado que imita uma rede corporativa. Eles permitem que o proprietário do access point inicie diversos ataques, até mesmo comprometendo potencialmente sessões com servidores seguros (usando um ataque de falsificação de DNS, por exemplo).

Redes de área pessoal (Personal Area Networks, PANs)

[[Redes de área pessoal (PANs)]] permitem a conectividade entre um dispositivo móvel e periféricos. Também é possível estabelecer redes ad hoc (ou ponto a ponto) entre dispositivos móveis ou entre dispositivos móveis e outros dispositivos de computação. Em termos de segurança corporativa, essas funções ponto a ponto geralmente devem ser desativadas.

Um invasor pode explorar um dispositivo configurado incorretamente e realizar uma conexão em ponte com a rede corporativa.

Wi-Fi Ad Hoc e Wi-Fi Direct

As estações wireless podem estabelecer conexões ponto a ponto entre si, em vez de usar um access point. Isso também pode ser chamado de [[rede ad hoc]], o que significa que a rede não é disponibilizada permanentemente. No entanto, não há suporte estabelecido baseado em padrões para redes ad hoc. A MITRE possui um projeto para permitir que smartphones Android se configurem em uma rede ad hoc ([mitre.org/research/technology-transfer/open-source-software/smartphone-ad-hoc-networking-span](https://www.mitre.org/research/technology-transfer/open-source-software/smartphone-ad-hoc-networking-span) (<https://www.mitre.org/research/technology-transfer/open-source-software/smartphone-ad-hoc-networking-span>)).

O Wi-Fi Direct permite conexões individuais entre estações, embora, neste caso, um dos dispositivos realmente funcione como um access point virtual. O Wi-Fi Direct depende da configuração Wi-Fi protegida (Wi-Fi Protected Setup, WPS), que tem muitas vulnerabilidades. O Android aceita funcionar como um Wi-Fi Direct AP, mas o iOS usa uma estrutura de conectividade multipeer proprietária. No entanto, você pode conectar um dispositivo iOS a outro dispositivo executando um Wi-Fi Direct SoftAP.

Há também produtos em malha wireless de fornecedores como Netgear e Google que permitem que todos os tipos de dispositivos sem fio participem de uma rede ponto a ponto. Esses produtos podem não ser interoperáveis, embora muitos agora sejam compatíveis com o padrão EasyMesh ([wi-fi.org/discover-wi-fi/wi-fi-easymesh](https://www.wi-fi.org/discover-wi-fi/wi-fi-easymesh) (<https://www.wi-fi.org/discover-wi-fi/wi-fi-easymesh>)).

Tethering e access points

Um smartphone pode compartilhar sua conexão web com outro dispositivo, como um PC. Quando essa conexão é compartilhada por Wi-Fi com vários outros dispositivos, o smartphone é descrito como um access point (hotspot). A conexão é compartilhada ao conectar o smartphone a um computador via cabo USB ou com um único computador via Bluetooth, prática também conhecida como [[tethering]]. No entanto, o termo “Wi-Fi tethering” é bastante usado para se referir a um access point.

Esse tipo de funcionalidade normalmente seria desativado quando o dispositivo estivesse conectado a uma rede corporativa, pois poderia ser usado para contornar mecanismos de segurança, como políticas de prevenção de perda de dados ou filtragem de conteúdo web.

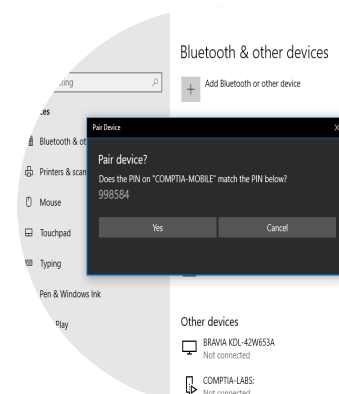


This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Bluetooth]] é uma tecnologia sem fio baseada em rádio, projetada para implementar redes de área pessoal de curto alcance. Alguns problemas de segurança associados ao Bluetooth são:

- **Descoberta de dispositivo:** ocorre quando um dispositivo pode ser colocado no modo detectável, de forma que ele possa se conectar a qualquer outro dispositivo Bluetooth nas proximidades. Infelizmente, mesmo um dispositivo no modo não detectável ainda pode ser detectado.
- **Autenticação e autorização:** ocorre quando os dispositivos são autenticados (emparelham) usando uma chave de acesso simples configurada nos dois dispositivos. Ela deve sempre ser alterada para uma frase segura e nunca deixada como padrão, como “0000”. Além disso, a lista de emparelhamento do dispositivo deve ser verificada regularmente para confirmar se os dispositivos listados são válidos.
- **Malware:** ocorre quando há worms Bluetooth de prova de conceito e softwares de exploração de vulnerabilidades em aplicativos, principalmente o BlueBorne ([armis.com/blueborne](https://www.armis.com/blueborne/)) (<https://www.armis.com/blueborne/>), que pode comprometer qualquer sistema ativo e sem patches, independentemente de a descoberta estar ativada e sem exigir qualquer intervenção do usuário. Há também vulnerabilidades nos esquemas de autenticação de muitos dispositivos. Mantenha os dispositivos atualizados com o firmware mais recente.

Figura 1. Emparelhamento de um computador com um smartphone.



Captura de tela usada com permissão da Microsoft.

Descrição

O painel esquerdo possui um botão de início, seguido de uma barra de pesquisa. Abaixo da barra, há uma lista de dispositivos. O painel direito está intitulado “Bluetooth e outros dispositivos”. Uma caixa de diálogo intitulada “Emparelhar Dispositivo” exibe: Emparelhar dispositivo? O texto abaixo diz: O PIN em “COMPTIA-MOBILE” corresponde ao PIN abaixo? 998584. Dois botões, sim e cancelar, estão presentes na parte inferior.

Nota:

Usar o botão do centro de controle talvez não desligue o sinal Bluetooth em um dispositivo móvel. Se houver alguma dúvida sobre o status do patch ou a exposição a vulnerabilidades, o Bluetooth deve ser totalmente desativado nas configurações do dispositivo.

A menos que a autenticação do dispositivo esteja configurada, um dispositivo em modo descobrível fica vulnerável ao [[bluejacking]], um tipo de spam em que alguém envia uma mensagem de texto (ou imagem/vídeo) não solicitada ou um vCard (detalhes de contato). Ele também pode ser um vetor de malware, como demonstrou o malware cavalo de troia para Android Obad(securelist.com/the-most-sophisticated-android-trojan/35929 (<https://securelist.com/the-most-sophisticated-android-trojan/35929/>)).

[[Bluesnarfing]] refere-se ao uso de uma exploração no Bluetooth para roubar informações do telefone de outra pessoa. A vulnerabilidade (agora corrigida) permite que os invasores burlam o mecanismo de autenticação. Mesmo sem uma exploração, um código PIN curto (quatro dígitos) é vulnerável à quebra de senha por força bruta.

Outros riscos significativos advêm da conexão entre dispositivos. Um dispositivo periférico com firmware mal-intencionado pode ser usado para iniciar ataques altamente eficazes. Esse tipo de risco tem uma probabilidade baixa, já que são necessários recursos significativos para criar periféricos mal-intencionados desse tipo.

Recursos de segurança do Bluetooth

O Bluetooth incorpora vários recursos de segurança para garantir a segurança dos dados e das comunicações.

Recurso	Descrição
Emparelhamento e autenticação	Durante o emparelhamento, os dispositivos trocam chaves criptográficas para autenticar a identidade um do outro e estabelecer um canal de comunicação seguro. O emparelhamento é realizado usando vários métodos, como comparação numérica, entrada de chave de acesso ou autenticação fora de banda (out-of-band, OOB).
Permissões do Bluetooth	O Bluetooth geralmente requer o consentimento ou a permissão do usuário para se conectar e acessar serviços específicos. Os usuários podem controlar quais dispositivos se conectam aos seus dispositivos habilitados para Bluetooth e gerenciar permissões para impedir o acesso não autorizado.
Encryption (criptografia)	O Bluetooth emprega algoritmos de criptografia para proteger os dados transmitidos entre os dispositivos. Quando o emparelhamento estiver concluído, os dispositivos Bluetooth usarão uma chave secreta compartilhada para criptografar os pacotes de dados.

Recurso	Descrição
Conexões seguras Bluetooth (Bluetooth Secure Connections, BSC)	Introduzido no Bluetooth 4.0, o BSC oferece maior resistência contra espionagem, ataques intermediários (on-path) e acesso não autorizado.
Privacidade do Bluetooth de baixa energia (Bluetooth Low Energy, BLE)	O BLE é uma versão eficiente em termos de energia do Bluetooth que usa endereços de dispositivos gerados aleatoriamente que mudam periodicamente para evitar o rastreamento e a identificação não autorizada de dispositivos BLE.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A [[comunicação por campo de proximidade (NFC)]] baseia-se em um tipo específico de identificação por radiofrequência (RFID). Os sensores de NFC e suas funcionalidades agora são comumente incorporados nos smartphones. Um chip NFC também pode ser usado para ler etiquetas RFID passivas a curta distância, configurar outros tipos de conexões (emparelhamento de dispositivos Bluetooth, por exemplo) e trocar informações como cartões de visita. Uma transação NFC é por vezes chamada de “bump”, em referência a um dos primeiros aplicativos de compartilhamento móvel, posteriormente reformulado como Android Beam, para usar a NFC.

O caso de uso típico são os pôsteres “inteligentes”, em que o usuário pode tocar na tag em um pôster para abrir uma página da web vinculada por meio de informações codificadas na tag.

Os ataques poderiam ser desenvolvidos ao usar vulnerabilidades no manuseio da tag (securityboulevard.com/2019/10/nfc-false-tag-vulnerability-cve-2019-9295 (<https://securityboulevard.com/2019/10/nfc-false-tag-vulnerability-cve-2019-9295/>)). Também é possível explorar a NFC criando tags para direcionar o navegador do dispositivo para uma página da web mal-intencionada, onde o invasor pode tentar explorar vulnerabilidades no navegador.

A NFC não possibilita criptografia, portanto, a espionagem e os ataques intermediários (on-path) são possíveis se o invasor conseguir encontrar alguma maneira de interceptar a comunicação e os serviços de software não estiverem criptografando os dados.

A aplicação mais ampla da NFC é fazer pagamentos por meio de máquinas de ponto de vendas (PoS) por aproximação. Para configurar um serviço de pagamento, o usuário insere as informações do seu cartão de crédito em um aplicativo de carteira virtual no dispositivo. O aplicativo de carteira não transmite as informações do cartão de crédito original, apenas um token de uso único, que é interpretado pelo comerciante do cartão e vinculado de volta à conta relevante do cliente.

Há três principais aplicativos de carteira virtual: Apple Pay, Google Pay (antigo Android Pay) e Samsung Pay.

Apesar da exigência de proximidade física, a NFC é vulnerável a vários tipos de ataques. Certas configurações de antena podem ser capazes de captar os sinais de RF emitidos por NFC a vários metros de distância, permitindo que um invasor capte a partir de uma distância mais confortável. Um invasor com um leitor também pode ser capaz de extrair informações de um dispositivo NFC em uma área lotada, como um trem cheio. Um invasor também consegue corromper os dados à medida que eles são transferidos por meio de um método semelhante a um ataque DoS, inundando a área com um excesso de sinais de RF para interromper a transferência.

Nota:

Da mesma forma, o roubo de um cartão fornecerá ao invasor o número do cartão completo e a data de validade. Concluir transações fraudulentas diretamente por meio da NFC é muito mais difícil, pois o invasor teria que usar uma conta de comerciante válida e as transações fraudulentas relacionadas a essa conta seriam detectadas muito rapidamente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de aplicar políticas e tecnologias de hardening do host e avaliar os riscos de cadeias de suprimentos de terceiros e sistemas integrados/IoT.

Diretrizes para implementar soluções de segurança do host

Siga estas diretrizes ao implantar ou reavaliar a segurança e a integração de endpoints com sistemas integrados ou de IoT:

- Estabeleça linhas de base de configuração para cada tipo de host. Garanta que os hosts sejam implantados na linha de base da configuração e configure o monitoramento para garantir a conformidade.
- Configure a criptografia completa do disco.
- Implante uma solução de proteção de endpoint que atenda aos requisitos de segurança para funções como antimalware, firewall, IDS, EDR e DLP.

- Estabeleça procedimentos de gerenciamento de patches para testar atualizações em diferentes grupos de hosts e garanta o gerenciamento do sistema operacional e de softwares de terceiros.
- Crie um plano de gerenciamento para dispositivos de IoT usados no local de trabalho.
- Avalie os requisitos de segurança para sistemas integrados ICS e/ou SCADA:
 - Aquisição de sistemas integrados e IoT seguros
 - Uso de controles criptográficos para autenticação, integridade e resiliência
 - Controle de acesso e segmentação para redes OT
 - Suporte do fornecedor para gerenciamento de patch



This content is only available on larger screen sizes. Please revisit this page on a larger device.